물리보안 시스템의 제로 트러스트 적용 백서

한빛시큐어 보안연구소 · 2026년 5월 · 공개용

1. 배경

출입통제와 영상감시 장비가 IP 네트워크로 연결되면서, 물리보안 장비 자체가 사이버 공격의 대상이 되고 있다. 특히 리더기와 컨트롤러 사이의 구형 Wiegand 통신은 암호화가 없어 신호를 가로채 카드를 복제하는 공격이 가능하다.

2. 제로 트러스트 원칙

제로 트러스트는 '내부망이라도 신뢰하지 않는다'는 원칙이다. 물리보안에 적용하면 다음과 같다.

- 모든 장비 간 통신을 암호화하고 상호 인증한다.
- 출입 권한은 최소 권한 원칙에 따라 구역·시간대별로 부여한다.
- 고보안 구역은 다중 인증(카드 + 생체)을 적용한다.
- 모든 이벤트를 기록하고 이상 징후를 지속적으로 분석한다.

3. 가디언 AC-100의 적용 사례

가디언 AC-100은 리더기-컨트롤러 구간에 Wiegand 대신 OSDP v2 Secure Channel을 사용한다. 카드는 MIFARE DESFire EV3를 사용하며 AES-128 암호화로 복제를 막는다. 컨트롤러와 관리 서버(GMS) 사이는 TLS 1.3으로 보호한다.

4. 남은 과제

- 얼굴인식 템플릿은 개인정보이므로 리더기에 저장하지 않고 GMS에 암호화 저장해야 한다. 현재 GR-200F는 성능 문제로 템플릿 일부를 리더기에 캐시하고 있어 개선이 필요하다.
- 컨트롤러 펌웨어 업데이트가 사업장마다 늦어지는 문제가 있다. 원격 일괄 업데이트 기능이 필요하다.
- 영상 데이터의 보관 기간이 길어질수록 유출 위험도 커진다. 보관 기간 정책과 접근 통제를 함께 설계해야 한다.

5. 결론

물리보안 장비도 IT 장비와 같은 수준의 보안 관리가 필요하다. 암호화 통신, 다중 인증, 펌웨어 관리, 데이터 보관 정책의 네 가지가 핵심이다.